

Zertifikate



Ist der Absender bzw. Inhaber des Schlüsselpaares wirklich die Person, für die ich ihn halte?

Und ist diese Person vertrauenswürdig? Letztlich fehlt die Gewissheit, dass der für die Signatur verwendete Public-Key wirklich von dem angegebenen Absender stammt und nicht von jemandem, der diese Identität nur vortäuscht (z.B. "Man-in-the-Middle")!

Das Zertifikat (to certify = beglaubigen; certificate = die Beglaubigung/Urkunde)

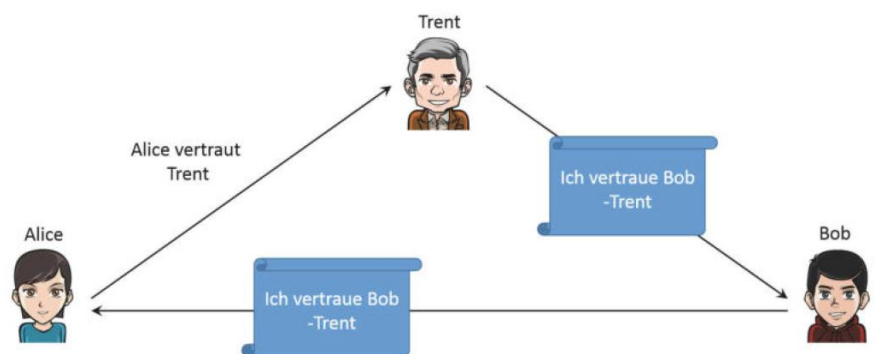
Ist der Partner nicht persönlich bekannt, so kann die Vertrauenswürdigkeit eines unterschriebenen Dokuments durch die Vorlage von einem gültigen Ausweis, behördlicher Beglaubigung oder notarieller Urkunde hergestellt werden (sofern diese echt sind). Ebenso wird eine **Signatur** anhand eines weiteren beglaubigten Dokumentes überprüft, dies ist das "**Zertifikat**".

→ Das Zertifikat beglaubigt die Bindung eines Public Keys an die Identität seines Inhabers.

Prinzip:

1. Alice traut Trent
2. Trent traut Bob
3. Deshalb traut Alice auch Bob

- Trent ist in der Praxis eine vertrauenswürdige Zertifizierungsstelle
→ **Certification Authority (CA)**
- Trent zertifiziert den Public Key von Bob mit seinem Private Key



Man weiß nun mit wem man es zu tun hat, das Zertifikat ist sozusagen ein elektronischer Ausweis, der von einer Zertifizierungsstelle (**CA / Certification Authority** bzw. **Trust Center**) ausgestellt wurde.

Gemäß **Signaturgesetz** müssen Zertifikate u.a. folgende Angaben beinhalten (oft wird der Standard X.509 verwendet):

Name der Zertifizierungsstelle (Trent)	Fingerprint erstellt aus allen Angaben
Name des Eigentümers (Bob)	
Public Key des Eigentümers (Bob)	
Gültigkeitszeitraum des Zertifikats (max. 5 Jahre)	
Verwendungsbereich	
Verwendete Algorithmen fürs Signieren und Hashen	
Link auf Zertifikatssperlliste	

Der Fingerprint (Hashwert) wird mit dem **Private Key** der CA signiert.



Wer beglaubigt die **Echtheit des Zertifikats**? Kann man der ausstellenden CA vertrauen?

Prinzipiell kann sich jeder auch selber ein Zertifikat ausstellen und die dazu erforderliche **PKI** (Public Key Infrastructure, also Key-Server) betreiben!

Letztlich ist es Sache des Empfängers, welcher CA er vertraut (nicht so ganz einfach...)!

Anerkannte CAs sind vorkonfiguriert im Zertifikatsspeicher von Betriebssystemen und Browsern enthalten, Aktualisierungen erfolgen mit Updates.